kiruba N
cyber security intern

April 2026

VULNERABILITY ASSESSMENT REPORT FOR A LIVE WEBSITE

Assessment Report of a public website (Read-only security analysis).

Table of Contents

1. Title & Introduction
2. Scope & Attributes
3. Risk Classification
4. Summary of Identified Vulnerabilities
5. Detailed Technical Information
6. Appendix

1. Title & Introduction

- Report Title: Vulnerability Assessment Report for a Live Website
- Project Name: Altoro Mutual Security Assessment
- Prepared By: kiruba N
- Executive Summary:
  This document describes the proceedings and results of a security assessment conducted against the Altoro Mutual web application. The assessment utilized automated scanning and manual inspection using OWASP ZAP, Nmap, and Gobuster to uncover 16 vulnerabilities. These findings range from medium-risk security misconfigurations to low-risk information disclosure issues.

2.Scope & Attributes

- Application Name: Altoro Mutual
- Target URL: http://demo.testfire.net
- IP Address: 65.61.137.117
- Assessment Attributes:

1. Starting Vector: External
2. Target Criticality: Medium (Demo Banking Site)
3. Nature: Cautious & Calculated
4. Proof of Concept: Attached where applicable

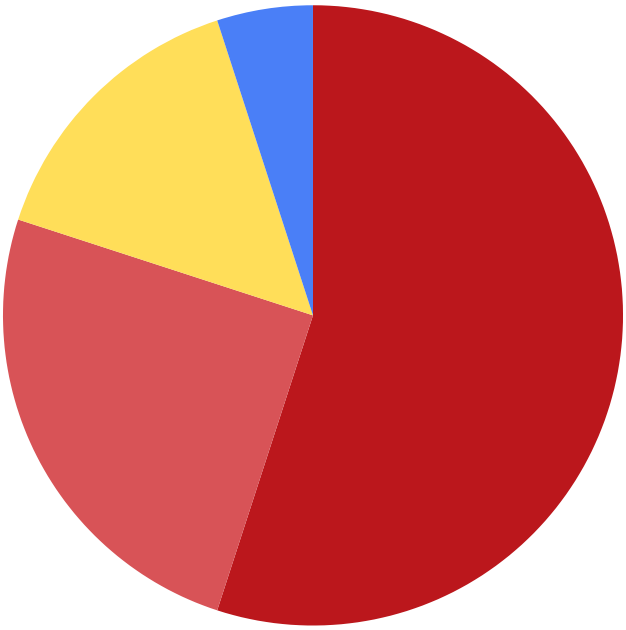
Risk Classification

Severity Ratings	Explanation
Critical	Exploitable publicly. No fix available from vendor.
High	Exploitable publicly. Fix/patch available.
Medium	No public exploit yet. Patch/workaround not yet released.
Low/Info	No direct threat. Reveals sensitive information or has available workarounds.

Risk Ratings

Critical **High** **Medium** **Low/Info**

vulnerability Assessment



4. Summary of Identified Vulnerabilities

Severity Count Findings

Medium – 5

- CSRF
- Missing CSP Header
- Cross-Domain Misconfiguration
- Missing Anti-clickjacking Header
- Subresource Integrity Missing

Low – 6

- Cookie without SameSite
- Server Version Information Leak
- X-Content-Type-Options Missing
- Strict Transport Security Missing
- Timestamp Disclosure

Info – 5

- Suspicious Comments
- Modern Web Application
- Session Management Identified
- Cache-related observations

Total 16 Unique Vulnerabilities Found

Detailed Comparison of Results

1. Medium Risk

The application contains multiple medium-risk vulnerabilities primarily related to missing security protections and improper configurations.

Absence of Anti-CSRF Tokens
Forms do not include CSRF tokens, allowing attackers to perform unauthorized actions.

Missing Content Security Policy (CSP)
No CSP header is defined, increasing XSS attack risk.

Cross-Domain Misconfiguration
Improper CORS settings may allow unauthorized domains.

Missing Anti-clickjacking Header
No X-Frame-Options header, making clickjacking possible.

Subresource Integrity Missing
External scripts are not verified for integrity.

2. Low Risk

Low-risk vulnerabilities mainly involve missing headers and information disclosure.

Cookie without SameSite Attribute
Cookies can be used in cross-site attacks.

Server Version Information Leak
Server reveals Apache-Coyote/1.1.

X-Content-Type-Options Missing
Allows MIME sniffing.

Strict Transport Security Not Set
HTTPS downgrade attacks possible.

Timestamp Disclosure
System timing information exposed.

3. Informational Findings

These do not directly affect security but provide useful information to attackers.

Suspicious Comments
May reveal internal logic.

Modern Web Application
Indicates application structure.

Session Management Identified
Shows session handling mechanism.

Cache Observations
Improper cache settings.

Directory Enumeration (Gobuster)
Directories like /admin, /bank, /static found.

5. Detailed Technical Information (VULN_01)

Vulnerability Name: Missing Content Security Policy (CSP)
Reference ID: VULN_01
Risk Rating: Medium
Tools Used: OWASP ZAP
CWE ID: 693

Vulnerability Description:
The application does not define a Content Security Policy header. This increases the risk of XSS attacks.

Vulnerable URL:
http://demo.testfire.net

Implications:
Attackers can inject malicious scripts and steal user data.

Suggested Countermeasures:
Implement a strict CSP header.

Vulnerability Name: Absence of Anti-CSRF Tokens
Reference ID: VULN_02
Risk Rating: Medium
CWE ID: 352

Description:
Forms lack CSRF protection.

Impact:
Unauthorized actions can be performed.

Fix:
Add CSRF tokens.

Vulnerability Name: Missing Anti-clickjacking Header
Reference ID: VULN_03
Risk Rating: Medium

Description:
No X-Frame-Options header present.

Impact:
Clickjacking attacks possible.

Fix:
Set X-Frame-Options: DENY

Vulnerability Name: Cross-Domain Misconfiguration
Reference ID: VULN_04
Risk Rating: Medium
Description:
Improper CORS configuration.
Impact:
Unauthorized data access.
Fix:
Restrict allowed domains.

Vulnerability Name: Subresource Integrity Missing
Reference ID: VULN_05
Risk Rating: Medium

Description:
External scripts are not verified.

Impact:
Tampered scripts may execute.

Fix:
Use integrity attribute.

Vulnerability Name: Server Version Information Leak
Reference ID: VULN_06
Risk Rating: Low

Description:
Server reveals version info.

Impact:
Helps attackers find exploits.

Fix:
Hide server headers.

Vulnerability Name: Cookie without SameSite Attribute
Reference ID: VULN_07
Risk Rating: Low

Impact:
Session hijacking possible.

Fix:
Set SameSite=Strict.

Vulnerability Name: X-Content-Type-Options Header Missing
Reference ID: VULN_08
Risk Rating: Low

Description:
The application does not include the X-Content-Type-Options header, which prevents browsers from MIME-type sniffing.

Impact:
Attackers may trick the browser into interpreting files incorrectly, leading to security risks.

Suggested Countermeasures:
Add the following header:
X-Content-Type-Options: nosniff

Vulnerability Name: Strict Transport Security (HSTS) Not Set
Reference ID: VULN_09
Risk Rating: Low

Description:
The application does not enforce HTTPS using HSTS.

Impact:
Attackers can downgrade secure connections (HTTPS → HTTP).

Suggested Countermeasures:
Enable HSTS header:
Strict-Transport-Security: max-age=31536000

Vulnerability Name: Directory Enumeration
Reference ID: VULN_10
Risk Rating: Informational
Tools Used: Gobuster

Vulnerability Description:
Directory enumeration revealed multiple hidden paths in the application.

Discovered Paths:

- /admin → redirected to login
- /bank → redirected to login
- /images
- /static
- /util

Implications:
Attackers can map the application structure and target sensitive endpoints.

Suggested Countermeasures:
Restrict access to sensitive directories and disable directory listing.

Vulnerability Name: Open Ports & Services Exposure
Reference ID: VULN_11
Risk Rating: Informational
Tools Used: Nmap

Description:
Multiple open ports were identified on the server.

Ports Identified:

- 80 (HTTP)
- 443 (HTTPS)
- 8080 (HTTP Alternate)

Service Detected:
Apache Tomcat (Apache-Coyote/1.1)

Impact:
Increases attack surface.

Suggested Countermeasures:
Close unused ports and restrict access using firewall rules.

Vulnerability Name: Information Disclosure – Suspicious Comments
Reference ID: VULN_12
Risk Rating: Informational

Description:
Comments found in HTML or scripts may reveal internal logic.

Impact:
Attackers can gain insight into application structure.

Suggested Countermeasures:
Remove all unnecessary comments before deployment.

6. Appendix

Heading: Visual Evidence

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 10:24 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.045s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp  open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
|_ssl-date: 2026-04-09T14:25:12+00:00; +4s from scanner time.
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8080/tcp open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual

Host script results:
|_clock-skew: 3s

Service detection performed. Please report any incorrect results at https://nmap.org/subm
it/ .
Nmap done: 1 IP address (1 host up) scanned in 52.66 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://demo.testfire.net -w /usr/share/wordlists/dirb/common.txt -t 50
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://demo.testfire.net
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
admin                (Status: 302) [Size: 0] [--> /login.jsp]
aux                  (Status: 200) [Size: 0]
bank                 (Status: 302) [Size: 0] [--> /login.jsp]
com3                 (Status: 200) [Size: 0]
com1                 (Status: 200) [Size: 0]
com2                 (Status: 200) [Size: 0]
con                  (Status: 200) [Size: 0]
images               (Status: 302) [Size: 0] [--> /images/]
lpt2                 (Status: 200) [Size: 0]
lpt1                 (Status: 200) [Size: 0]
nul                  (Status: 200) [Size: 0]
pr                   (Status: 302) [Size: 0] [--> /pr/]
prn                  (Status: 200) [Size: 0]
static               (Status: 302) [Size: 0] [--> /static/]
util                 (Status: 302) [Size: 0] [--> /util/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 11:36 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.036s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp  open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
|_ssl-date: 2026-04-04T15:37:38+00:00; +3s from scanner time.
8080/tcp open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual

Host script results:
|_clock-skew: 2s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.81 seconds

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 10:24 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.045s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
443/tcp  open  ssl/http Apache Tomcat/Coyote JSP engine 1.1
|_ssl-date: 2026-04-09T14:25:12+00:00; +4s from scanner time.
| ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after:  2026-06-21T23:59:59
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8080/tcp open  http     Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual

Host script results:
|_clock-skew: 3s
```

ZAP by Checkmarx Scanning Report

Generated with ZAP on Wed 8 Apr 2026, at 00:35:18

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk

Conclusion

The Altoro Mutual application has critical security gaps, mainly missing security headers and a CSRF vulnerability. While most issues can be fixed quickly through configuration changes, the CSRF issue requires development effort. Addressing these will significantly improve the application’s security posture and reduce potential risks.